

Bug Reports — FR02: Login Feature

1. Bug Reports

BUG-01: Tiêu đề trang Login hiển thị sai

Field	Detail
Bug ID	BUG-01
Phát hiện tại	Domain Testing (kiểm tra UI thủ công)
Severity	Minor
Priority	Low
Feature	FR-02
Summary	Tiêu đề trang Login hiển thị "Đăng kí" thay vì "Đăng nhập"
Steps to Reproduce	1. Vào http://localhost:5173/login
Expected	Tiêu đề hiển thị "Đăng nhập"
Actual	Tiêu đề hiển thị "Đăng kí"
Screenshot	screenshots/bug-01-wrong-title.png

BUG-02: Không hiển thị thông báo khi tài khoản bị khóa (silent logout)

Field	Detail
Bug ID	BUG-02
Phát hiện tại	TC-11, TC-12 (Domain Testing) + BVA-04 (BVA) — cùng một lỗi
Severity	Major
Priority	High
Feature	FR-02
Summary	Sau đúng 3 lần đăng nhập sai (on-point boundary), tài khoản bị khóa nhưng không hiển thị thông báo, không có bộ đếm ngược thời gian
Steps to Reproduce	1. Vào http://localhost:5173/login 2. Nhập đúng email, sai password 3 lần liên tiếp 3. Thử nhập đúng password
Expected	Hiển thị "Tài khoản bị tạm khóa, vui lòng thử lại sau X giây"
Actual	Không có thông báo, người dùng không biết lý do tại sao không đăng nhập được dù nhập đúng thông tin
Screenshot	screenshots/bug-02-no-logout-message.png

BUG-03: Mật khẩu không được ẩn khi nhập

Field	Detail
Bug ID	BUG-03
Phát hiện tại	Domain Testing (kiểm tra UI)
Severity	Major
Priority	Medium
Feature	FR-02
Summary	Khi điền mật khẩu, nội dung không được ẩn bằng ký tự đặc biệt
Steps to Reproduce	1. Vào http://localhost:5173/login 2. Điền thông tin mật khẩu
Expected	Các ký tự đã nhập được ẩn bằng ký tự đặc biệt như *, #
Actual	Nội dung mật khẩu được hiển thị toàn bộ
Screenshot	screenshots/bug-03-password-is-not-hidden.png

BUG-04: User thường tự đổi role thành admin (role escalation)

Field	Detail
Bug ID	BUG-04
Phát hiện tại	TC-19 (Domain Testing)
Severity	Critical
Priority	High
Related	SEC-06
Summary	User thường gọi API <code>PUT /api/users/me</code> với body <code>{"role": "admin"}</code> → thành công, role được cập nhật thành admin — vi phạm SEC-06
Steps to Reproduce	1. Đăng nhập tài khoản user thường 2. Gọi <code>PUT /api/users/me</code> với body <code>{"role": "admin"}</code> 3. Response trả về thành công
Expected	Backend bỏ qua trường role, trả về lỗi hoặc giữ nguyên role cũ
Actual	Response trả về update thành công, role = "admin"
Screenshot	screenshots/bug-04-role-escalation.png

BUG-05: Lockout kích hoạt sớm hơn ngưỡng spec (off-by-one)

Field	Detail
Bug ID	BUG-05

Field	Detail
Phát hiện tại	BVA-03
Severity	Major
Priority	High
Summary	Tại 2 lần sai (dưới ngưỡng biên theo spec là 3 lần), hệ thống đã kích hoạt lockout — sai logic đếm attempts (off-by-one)
Steps to Reproduce	1. Đăng nhập đúng email 2. Nhập sai password đúng 2 lần liên tiếp 3. Thử nhập lại
Expected	Vẫn cho phép thử lại vì chưa đạt ngưỡng 3 lần sai
Actual	Tài khoản đã bị khóa ngay sau 2 lần sai, không cho thử lại

BUG-06: Thời gian khóa tài khoản thực tế khác spec (3 phút thay vì 30 giây)

Field	Detail
Bug ID	BUG-06
Phát hiện tại	TC-14 (Domain Testing) + BVA-06, BVA-07, BVA-08 (BVA) — cùng một lỗi
Severity	Minor
Priority	High
Summary	Thời gian lockout thực tế là 3 phút, không phải 30 giây như spec quy định
Steps to Reproduce	1. Trigger lockout (sai password 3 lần) 2. Đợi đúng 30 giây (và 31 giây) 3. Đăng nhập lại bằng password đúng
Expected	Mở khóa và đăng nhập thành công sau đúng 30 giây
Actual	Sau 30s và 31s tài khoản vẫn bị khóa, phải chờ đến 3 phút mới đăng nhập lại được

BUG-07: Hệ thống không trim khoảng trắng trong password

Field	Detail
Bug ID	BUG-07
Phát hiện tại	TC-15 (Domain Testing)
Severity	Minor
Priority	Medium
Feature	FR-02

Field	Detail
Summary	Khi password có khoảng trắng thừa (ví dụ ở đầu chuỗi), hệ thống không tự động trim, dẫn đến đăng nhập thất bại dù phần ký tự chính xác
Steps to Reproduce	- Vào <code>http://localhost:5173/login</code> - Nhập đúng email - Nhập password đúng nhưng có khoảng trắng thừa (ví dụ: " pass") - Nhấn đăng nhập
Expected	Hệ thống tự động trim khoảng trắng thừa và xác thực đúng, hoặc nếu không trim thì cần rõ ràng trong spec là case này được xem là "sai" một cách có chủ đích
Actual	Hệ thống không trim, hiển thị "Đăng nhập thất bại" mà không có thông báo rõ ràng lý do (không phân biệt được với trường hợp sai password thật)
Screenshot	screenshots/bug-07-password-not-trimmed.png

BUG-08: Email không được xử lý case-insensitive

Field	Detail
Bug ID	BUG-08
Phát hiện tại	TC-16 (Domain Testing)
Severity	Major
Priority	Medium
Feature	FR-02
Summary	Khi nhập email đúng nhưng viết hoa toàn bộ (ví dụ USER@GMAIL.COM thay vì user@gmail.com), hệ thống báo đăng nhập thất bại thay vì xử lý case-insensitive như chuẩn thông thường của địa chỉ email
Steps to Reproduce	- Vào <code>http://localhost:5173/login</code> - Nhập email đúng nhưng viết hoa toàn bộ domain/local part (ví dụ: USER@GMAIL.COM) - Nhập đúng password - Nhấn đăng nhập
Expected	Đăng nhập thành công (email theo chuẩn RFC 5321 nên được so khớp case-insensitive, ít nhất ở phần domain)
Actual	Đăng nhập thất bại, hệ thống coi email viết hoa là tài khoản không tồn tại/không khớp
Screenshot	screenshots/bug-08-email-case-sensitive.png

2. AI Gap Analysis

Gap	Mô tả	Lý do AI bỏ sót
BUG-01, BUG-03 (UI/visual)	Sai tiêu đề, password không ẩn	AI không chạy app thực tế, chỉ phân tích logic — không phát hiện được lỗi UI visual
BUG-02 (thông báo lockout)	Lockout xảy ra nhưng silent	AI tin tưởng spec 100% — nếu spec ghi "có thông báo lockout" thì AI assume đúng, không kiểm tra UX thực tế
BUG-05 (off-by-one attempts)	Lockout kích hoạt ở 2 thay vì 3 lần sai	Domain testing thông thường không đủ chi tiết ở từng mốc biên; chỉ BVA test chính xác tại các điểm on-point/just-below/just-above mới phát hiện được
BUG-06 (time boundary)	Test chính xác tại 29s/30s/31s cho thấy lockout kéo dài 3 phút	AI không thể đo thời gian thực thi hệ thống — cần con người test thủ công theo đồng hồ
BUG-07 (trim khoảng trắng)	Behavior với password có khoảng trắng thừa	AI không biết implementation detail của backend
BUG-08 (case-insensitive email)	Email viết hoa bị coi là không hợp lệ	Logic nghiệp vụ ẩn, AI không suy luận được nếu không có spec rõ ràng
Chung	Prompt chưa yêu cầu kiểm tra UI/UX/security cụ thể	Cần bổ sung prompt: "check UI labels, messages, security edge cases" để AI sinh test case bao quát hơn

3. Test Summary

Metric	Value
Total test cases	35 (19 Domain + 16 BVA)
Executed	35
Passed	18
Failed	17
Not executed	0
Unique bugs found	8